C O D E R H O U S E

CIBERSEGURIDAD

Reporte de Análisis de Phishing

Caso universitario y defensa multicapa

Unidad 4 | Preentrega 4

Estudiante	Juan Skobalski
Curso	Ciberseguridad
Contexto	Seguridad universitaria
Fecha	3 de noviembre de 2026

Evaluación de señales de alerta, exposición, respuesta inmediata y prevención.

Introducción

Este reporte analiza un intento de phishing simulado dirigido a un profesor universitario. El mensaje utiliza un beneficio económico y un plazo limitado para inducirlo a iniciar sesión en un portal externo y entregar datos bancarios. El caso representa un ataque de **Ingeniería Social**: el atacante intenta obtener la cooperación de la víctima manipulando sus emociones y su percepción de autoridad.

Escenario recibido

Correo reportado por el profesor

"Estimado docente, su bonificación por investigación ha sido aprobada. Inicie sesión en `portal-universitario-pagos.net` para confirmar sus datos bancarios antes de las 5:00 PM para recibir el depósito hoy mismo."

Objetivo y alcance

El análisis se limita a los cuatro resultados solicitados:

- identificar al menos cuatro señales de alerta;
- explicar la exposición personal e institucional;
- establecer tres acciones inmediatas para la universidad;
- redactar un boletín preventivo de hasta 100 palabras.

No se abre ni se consulta el dominio sospechoso. En un incidente real se preservaría el mensaje original, incluyendo sus encabezados, para analizar el remitente, la autenticación del correo y la infraestructura utilizada.

Evaluación inicial: la promesa económica, el plazo urgente, el dominio externo y la solicitud de datos bancarios forman un patrón consistente con phishing orientado al robo de credenciales e información financiera.

Metodología

Se comparan los elementos del mensaje con procedimientos institucionales esperables y se aplica un enfoque de defensa multicapa: personas, correo electrónico, identidad, red, monitoreo y respuesta. Ningún control aislado se considera suficiente.

1. Identificación de señales de alerta

N.º	Señal	Justificación
1	**Dominio no institucional**	`portal-universitario-pagos.net` no demuestra pertenencia a la universidad. Combina términos confiables para parecer un portal oficial.
2	**Urgencia artificial**	El límite “antes de las 5:00 PM” busca reducir el tiempo disponible para pensar y verificar.
3	**Beneficio inesperado**	La bonificación apela a la gratificación y puede hacer que la víctima ignore inconsistencias.
4	**Datos sensibles**	Se solicitan credenciales y datos bancarios mediante un enlace recibido por correo, procedimiento de alto riesgo.
5	**Saludo genérico**	“Estimado docente” no identifica al profesor ni aporta información específica del trámite.
6	**Procedimiento atípico**	Una bonificación legítima debería figurar en los sistemas administrativos oficiales y poder confirmarse sin usar el enlace recibido.

Spoofing y apariencia confiable

El mensaje intenta realizar *spoofing* de identidad: adopta el lenguaje y la autoridad de la universidad para que la víctima lo trate como legítimo. Un logotipo, una firma o un diseño profesional no prueban el origen porque pueden copiarse. También debe diferenciarse el nombre visible de la dirección real del remitente.

El candado no sería suficiente

Aunque el portal utilizara HTTPS, eso solo cifraría la conexión con ese servidor. No demostraría que el sitio pertenece a la universidad. La validación debe comenzar por el dominio institucional y por un acceso independiente al sistema oficial.

Conclusión técnica: la evaluación no depende de una sola señal. La combinación de dominio externo, urgencia, recompensa y solicitud de datos sensibles permite clasificar el mensaje como un intento de phishing.

2. Exposición de riesgos

Si el profesor introduce sus datos en el portal, el incidente puede superar el fraude individual y convertirse en un acceso inicial contra la universidad.

Riesgo	Consecuencia posible
Robo de credenciales	Acceso no autorizado al correo, campus virtual, almacenamiento y otros servicios institucionales.
Fraude financiero	Uso indebido de datos bancarios, intentos de cobro o nuevas solicitudes fraudulentas.
Secuestro de la cuenta	Cambio de contraseña, persistencia mediante sesiones activas y pérdida de control por parte del profesor.
Propagación interna	Envío de nuevos correos desde una cuenta legítima para engañar a colegas, estudiantes o personal administrativo.
Movimiento lateral	Intentos de acceder a sistemas adicionales, especialmente si existe reutilización de contraseñas o privilegios elevados.
Filtración de información	Exposición de documentos, investigaciones, datos personales y comunicaciones internas.

Cadena probable del incidente

1. El profesor abre el portal y entrega credenciales o datos bancarios.
2. El atacante prueba las credenciales contra el correo y otros servicios conectados.
3. Si logra acceder, roba información o utiliza la cuenta para enviar phishing interno más convincente.
4. La confianza en una cuenta institucional facilita la propagación y amplía el impacto.

Factores que reducen el impacto

La autenticación multifactor (MFA), las contraseñas únicas, la revocación rápida de sesiones y el principio de menor privilegio limitan el alcance. MFA no elimina todos los ataques, pero agrega una barrera relevante si la contraseña fue robada.

Riesgo principal: la cuenta del profesor puede transformarse en una identidad confiable controlada por el atacante y utilizarse como punto de entrada para nuevos fraudes.

3. Plan de acción inmediato

La universidad debe actuar sobre el mensaje reportado y, al mismo tiempo, determinar si otras personas lo recibieron o interactuaron con él.

Paso 1. Contener y preservar

Bloquear temporalmente el dominio, la URL y el remitente en los controles de correo, DNS o navegación; buscar copias del mensaje y ponerlas en cuarentena. Conservar el correo original con sus encabezados para mantener evidencia y extraer indicadores verificables.

Paso 2. Investigar y proteger identidades

Identificar destinatarios, clics, formularios enviados e inicios de sesión anómalos. Si alguien interactuó, restablecer sus credenciales, revocar sesiones, revisar reglas de reenvío y aplicar o reforzar MFA. También deben monitorearse intentos posteriores desde la cuenta afectada.

Paso 3. Comunicar y prevenir

Enviar una alerta breve al personal con el asunto, el dominio y la conducta esperada; recordar cómo reportar el mensaje y acceder a los sistemas por canales oficiales. Compartir los indicadores con soporte y seguridad para mantener el bloqueo y el seguimiento.

Justificación de la secuencia

La contención reduce nuevas víctimas; la investigación determina el alcance real; y la comunicación evita que el mismo pretexto siga funcionando. Ejecutar solo una de estas acciones dejaría una parte del riesgo sin tratar.

Resultado esperado: retirar el correo, impedir el acceso al portal, proteger las cuentas afectadas y advertir a la comunidad antes de que el ataque se propague.

4. Defensa multicapa

Capa	Medida de mitigación
Personas	Capacitación, simulaciones autorizadas y técnica de la lupa sobre el enlace.
Correo electrónico	Filtros de reputación, análisis de URL y configuración de SPF, DKIM y DMARC para reducir suplantaciones del dominio propio.
Identidad	MFA, contraseñas únicas, acceso condicional y revocación de sesiones comprometidas.
Red y navegación	Filtrado DNS/web para bloquear dominios confirmados como maliciosos.
Monitoreo	Alertas por inicios de sesión anómalos, nuevas reglas de correo y comportamiento inusual.
Respuesta	Canal visible de reporte, responsables definidos y procedimiento documentado de contención e investigación.

Boletín preventivo para estudiantes

La lupa sobre el enlace - 83 palabras

Antes de abrir un enlace, coloca el cursor sobre él sin hacer clic. Compara la dirección mostrada con el dominio oficial de la universidad. En este caso, `portal-universitario-pagos.net` no pertenece al dominio institucional: combina palabras confiables para parecer legítimo. Si el destino es diferente, está acortado o solicita credenciales o datos bancarios, no ingreses. Abre el portal escribiendo manualmente la dirección oficial o desde la aplicación institucional. Reporta el mensaje a Soporte. La urgencia y una promesa de dinero nunca reemplazan la verificación.

Aplicación del semáforo de riesgo

- **Verde:** comunicación esperada, dominio institucional y trámite verificable en el portal oficial.
- **Amarillo:** beneficio inesperado, saludo genérico o procedimiento poco habitual; detenerse y verificar.
- **Rojo:** dominio externo, urgencia y solicitud de credenciales o datos bancarios; no interactuar y reportar.

Conclusión

El correo presenta señales suficientes para clasificarlo como phishing. Su eficacia depende de combinar autoridad, recompensa y urgencia para que el profesor entregue información sin verificar el procedimiento. El riesgo incluye fraude personal, compromiso de la cuenta y propagación dentro de la universidad.

La respuesta adecuada integra personas y tecnología: contener el mensaje, investigar el alcance, proteger identidades con MFA, bloquear indicadores y comunicar el caso. La técnica más simple para el usuario sigue siendo interrumpir la acción y verificar el enlace y el trámite desde un canal institucional independiente.